

# Cyber Security Assessment Report

**PREPARED FOR :**

Future Interns

08 July 2026

**Prepared By :**

Subhankar Mohanty

Cyber Security Intern

# Table of Contents

- Executive Summary
- Objective
- Scope
- Testing Environment
- Tools Used
- Methodology
- Nmap Assessment
- Nikto Assessment
- Browser Developer Tools Analysis
- Risk Summary
- Recommendations
- Conclusion

# Executive Summary

This report presents the results of a vulnerability assessment conducted on the Damn Vulnerable Web Application (DVWA) using Kali Linux in a controlled laboratory environment. The assessment was performed using Nmap, Nikto, and Firefox Browser Developer Tools to identify common web application security issues.

The assessment identified several findings, including missing HTTP security headers, server information disclosure, and an exposed database service. These vulnerabilities can increase the risk of information disclosure and potential attacks if left unaddressed. The findings and recommendations in this report provide practical guidance for improving web application security. This assessment also strengthened my understanding of vulnerability assessment techniques and the use of basic penetration testing tools in a safe and ethical environment.

# Objective & Scope

## Objective:

- Identify common web vulnerabilities.
- Perform a basic security assessment.
- Analyze HTTP communication.
- Classify risks.
- Recommend security improvements.

## Scope:

| Item            | Details                          |
|-----------------|----------------------------------|
| TARGET          | DVWA                             |
| Environment     | Kali Linux                       |
| Assessment Type | Passive Vulnerability Assessment |
| Target IP       | 127.0.0.1                        |

# Testing Environment & Tools

## Testing Environment:

- Operating System: Kali Linux
- Browser: Firefox
- Target: DVWA
- Database: MariaDB

## Tools Used:

| Tools      | Purpose          |
|------------|------------------|
| kali Linux | Testing Platform |

# Nmap

# Service Discovery

# Nikto

# Web Server Scan

# Firefox Browser Developer Tools

# HTTP Analysis

The screenshot shows the DVWA web application running in a browser. The browser's address bar displays '127.0.0.1:42001/index.php'. The page features a dark header with the DVWA logo. On the left, a sidebar lists various modules: Home (highlighted), Instructions, Setup / Reset DB, Bruteforce, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection, SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored), CSP Bypass, JavaScript, Authorisation Bypass, Open HTTP Redirect, and Cryptography. The main content area is titled 'Welcome to Damn Vulnerable Web Application!' and includes a paragraph about the application's purpose, a 'General Instructions' section, a 'WARNING!' section, and a 'Disclaimer'.

**Welcome to Damn Vulnerable Web Application!**

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.

The aim of DVWA is to **practice some of the most common web vulnerabilities**, with **various levels of difficulty**, with a simple straightforward interface.

---

### General Instructions

It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.

Please note, there are **both documented and undocumented vulnerabilities** with this software. This is intentional. You are encouraged to try and discover as many issues as possible.

There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.

---

### WARNING!

Damn Vulnerable Web Application is damn vulnerable! **Do not upload it to your hosting provider's public html folder or any Internet facing servers**, as they will be compromised. It is recommend using a virtual machine (such as [VirtualBox](#) or [VMware](#)), which is set to NAT networking mode. Inside a guest machine, you can download and install [XAMPP](#) for the web server and database.

---

### Disclaimer

# (DVWA)

# Methodology

DVWA Setup



Information Gathering



Nmap Scan



Nikto Scan



Browser Developer Tools Analysis



Risk Assessment



Recommendations

# Nmap Assessment

## Purpose:

Nmap was used to identify open ports and detect services running on the target system. This helps understand which network services are accessible and may require further security review.

## Command Used:

```
nmap -sV 127.0.0.1
```

```
(kali@kali)-[~]
$ nmap -sV 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-03 08:08 EDT
Stats: 0:00:06 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
Stats: 0:00:11 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000010s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
3306/tcp open  mysql?
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port3306-TCP:V=7.95I=7%D=7/3%Time=6A47A631P=x86_64-pc-linux-gnu(NUL
SF:L,67,"c\0\0\0\n11\.8\3-MariaDB-1\b1\x20from\x20Debian\0\x8c\x19\0\0\0+
SF:,a;H7x{\0xfe\xff-\x02\0\xff\x81\x15\0\0\0\0\0=\0\0\0\0\4\|670g9%\}*2\
SF:0mysql_native_password\0")%(GenericLines,9F,"c\0\0\0\n11\.8\3-MariaDB
SF:-1+b1\x20from\x20Debian\0\x8c\x19\0\0\0,a;H7x{\0xfe\xff-\x02\0\xff\x8
SF:1\x15\0\0\0\0\0\0\0=\0\0\0\0\4\|670g9%\}*2\0mysql_native_password\x004\0\0
SF:\x01\xffj\x04#HY000Proxy\x20header\x20is\x20not\x20accepted\x20from\x20
SF:127\0\0\0\0\1")%(LDAPBindReq,67,"c\0\0\0\n11\.8\3-MariaDB-1\b1\x20fr
SF:m\x20Debian\0\x9d\x19\0\0\|\|.ijt--U\0\xfe\xff-\x02\0\xff\x81\x15\0\0\0\
SF:0\0\0=\0\0\0nJe?H-Hd=CwQ\0mysql_native_password\0")%(afp,67,"c\0\0\0\
SF:n11\|.8\3-MariaDB-1\b1\x20from\x20Debian\0\xa7\x19\0\0V\$\$PElqs\0xfe
SF:fff-\x02\0\xff\x81\x15\0\0\0\0\0=\0\0\0nN{CyW)\d>E\$\"'\0mysql_native_
SF:password\0");
```

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/>.

Nmap done: 1 IP address (1 host up) scanned in 16.27 seconds

## (Nmap Service Version Detection Result)



# Observation:

- The target host (127.0.0.1) was reachable.
- 999 scanned TCP ports were closed.
- Port 3306/TCP was open.
- The open service was identified as MySQL/MariaDB.
- The exact service version could not be identified.

**Risk** —————→ **Medium**

# Recommendation:

- Restrict access to port 3306 using firewall rules.
- Allow connections only from trusted hosts.
- Use strong passwords for database accounts.
- Keep the database software updated with security patches.

# Nikto Assessment

## Purpose:

The objective of the Nikto scan was to identify common web server misconfigurations and security issues in the DVWA application.

## Command Used:

```
nikto -h http://127.0.0.1:42001
```

```
(kali㉿kali)-[~]
$ nikto -h http://127.0.0.1:42001
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 42001
+ Start Time: 2026-07-03 14:31:48 (GMT-4)

+ Server: nginx/1.26.3
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page / redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /login.php: Admin login page/section found.

+ 8074 requests: 0 error(s) and 3 item(s) reported on remote host
+ End Time: 2026-07-03 14:32:30 (GMT-4) (42 seconds)

+ 1 host(s) tested

(kali㉿kali)-[~]
$
```

( Nikto Web Server Scan Result)

# Findings:

| Finding                               | Risk          | Description                                                                                                                          |
|---------------------------------------|---------------|--------------------------------------------------------------------------------------------------------------------------------------|
| Missing X-Frame-Options Header        | Medium        | The web server does not include the X-Frame-Options header, which may allow clickjacking attacks.                                    |
| Missing X-Content-Type-Options Header | Low           | The browser may incorrectly interpret file types because the X-Content-Type-Options header is missing.                               |
| Login Page Detected                   | Informational | Nikto detected the application's login page (login.php), confirming the authentication interface is publicly accessible.             |
| Server Information Disclosure         | Low           | The server reveals that it is running <b>nginx/1.26.3</b> , providing information that could assist attackers during reconnaissance. |

## Recommendations:

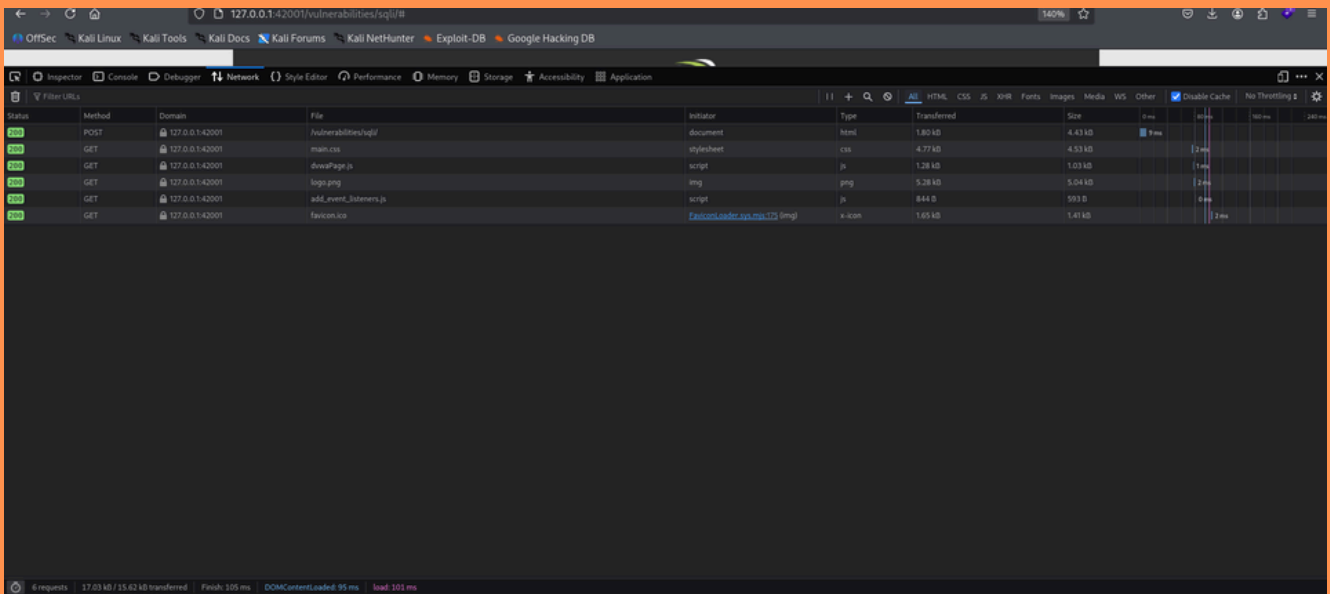
- Configure the X-Frame-Options header (for example, DENY or SAMEORIGIN) to protect against clickjacking.
- Enable the X-Content-Type-Options: nosniff header to prevent MIME type sniffing.
- Reduce unnecessary server information disclosure by hiding the server version.
- Regularly perform vulnerability scans using Nikto to identify web server configuration issues.

# Browser Developer Tools

## Tools Analysis

### Network Tab:

The Network tab was used to monitor HTTP requests and responses. It confirmed successful communication between the browser and the DVWA server with an HTTP 200 OK response.

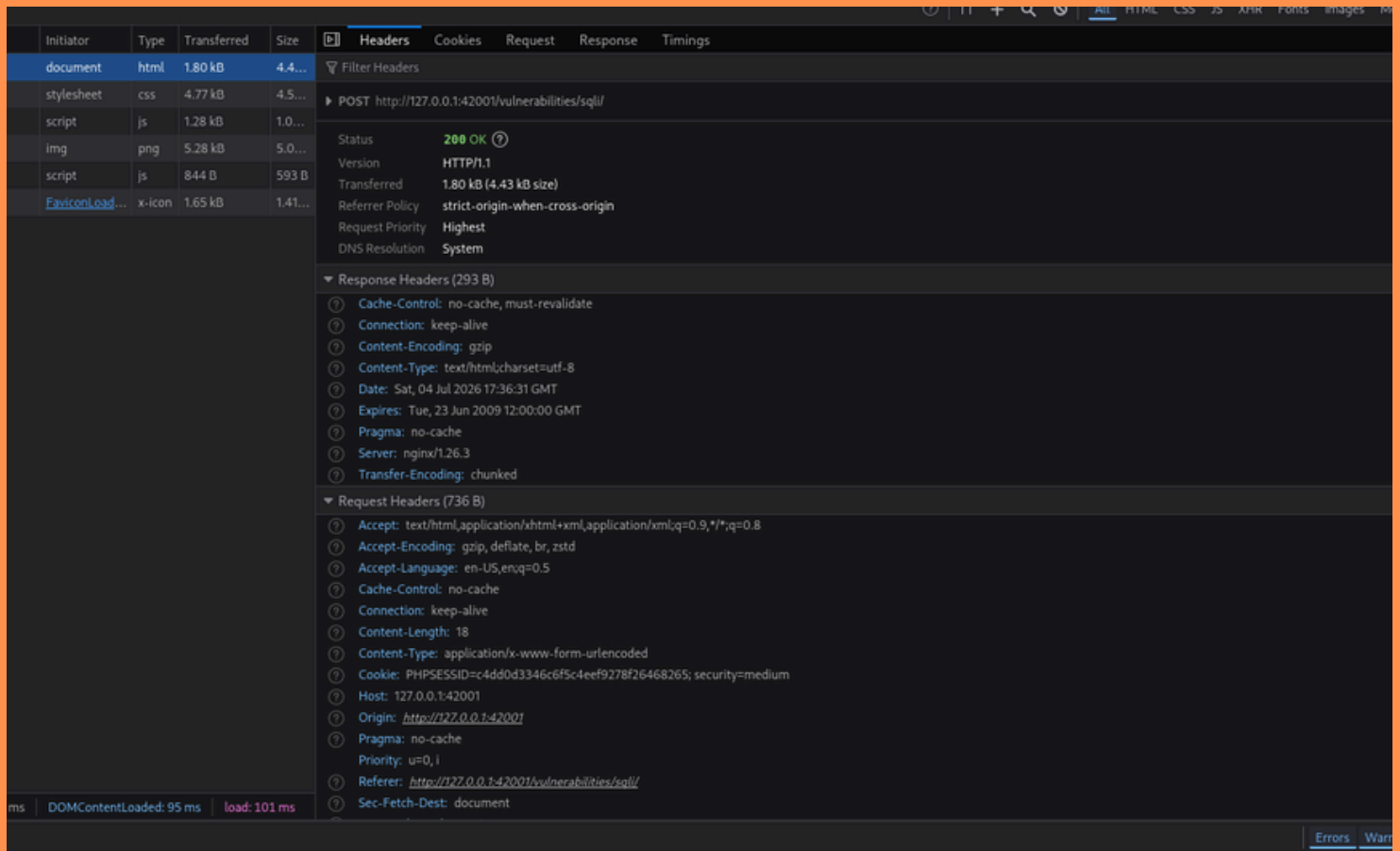


### (Browser Developer Tools – Network Tab)

### Headers:

The Headers section was analyzed to examine the HTTP response returned by the server.

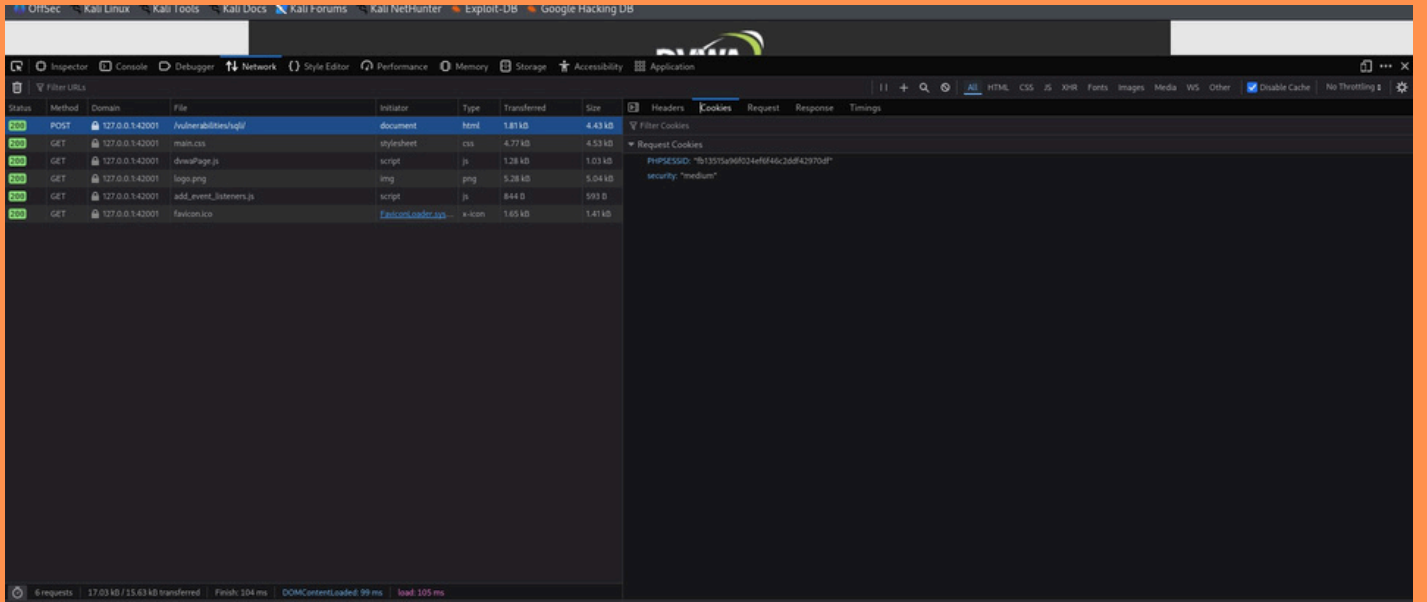
The server responded with an HTTP 200 OK status, indicating that the request was processed successfully.



( HTTP Response Headers)

## Cookies:

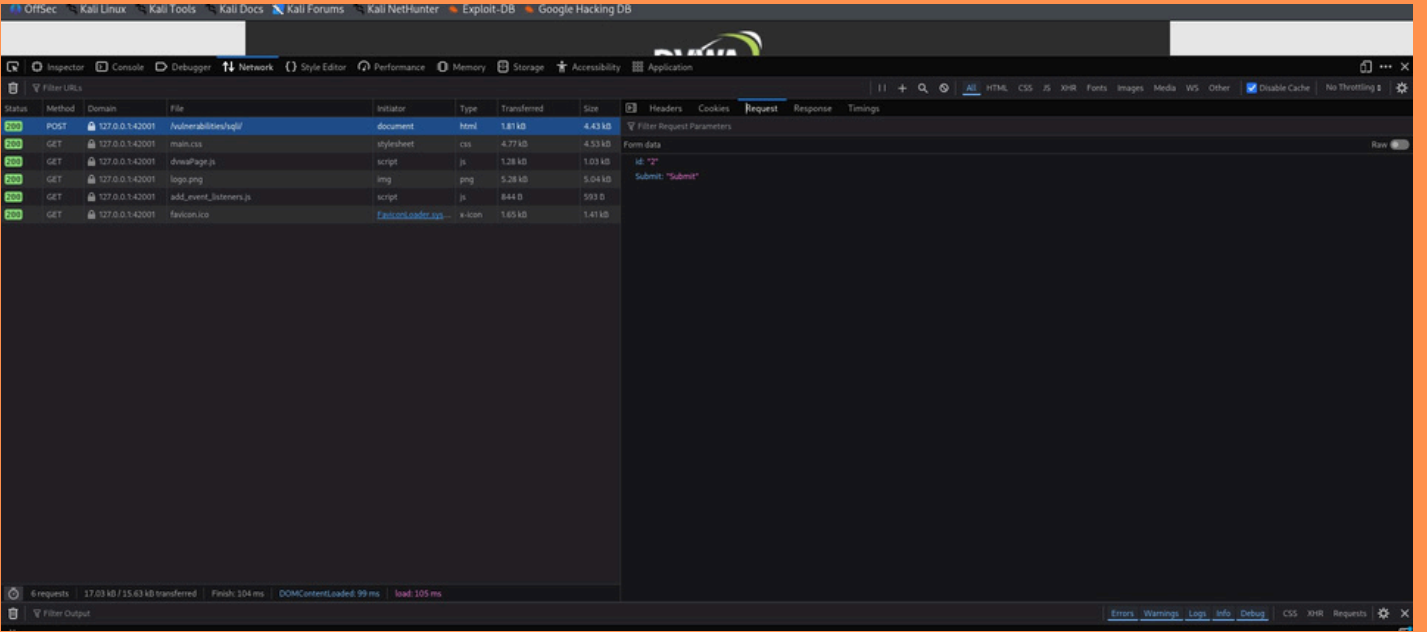
The application used PHPSESSID for session management and a security cookie to indicate the DVWA security level.



# (Browser Developer Tools – Cookies)

# Request:

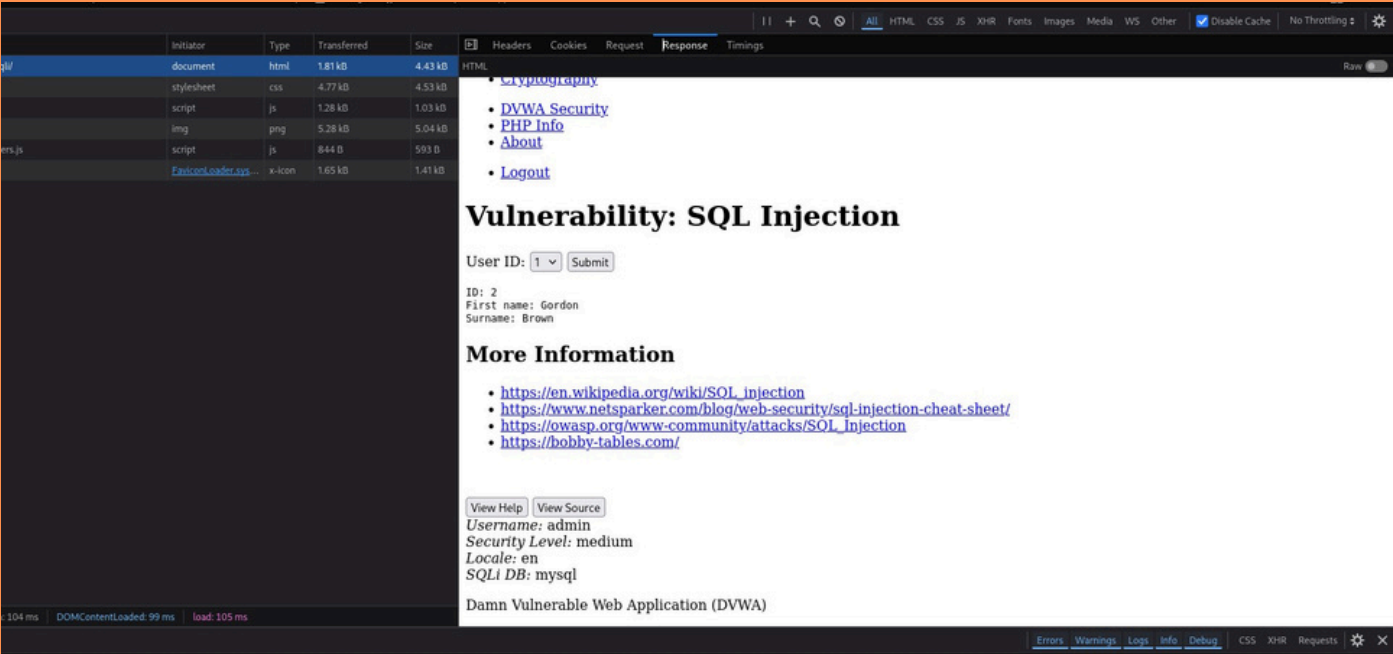
A POST request submitted the parameter:  
id=2



# ( HTTP POST Request)

# Response:

The application returned the corresponding user information successfully.



(HTTP Response)

# Risk Summary:

| Finding | Risk | Recommendation |
|---------|------|----------------|
|---------|------|----------------|

|                                |        |                                                |
|--------------------------------|--------|------------------------------------------------|
| Open Database Port             | Medium | Restrict database access using firewall rules. |
| Missing X-Frame-Options        | Medium | Configure X-Frame-Options header.              |
| Missing X-Content-Type-Options | Low    | Configure X-Content-Type-Options: nosniff.     |
| Server Banner Disclosure       | Low    | Hide server version information.               |

## Recommendations:

- Restrict unnecessary network access.
- Configure HTTP security headers.
- Hide server version information.
- Regularly update software.
- Use strong authentication.
- Perform periodic vulnerability assessments.
- Follow OWASP security best practices.



# Conclusion:

The vulnerability assessment of the Damn Vulnerable Web Application (DVWA) was successfully completed using Kali Linux, Nmap, Nikto, and Firefox Browser Developer Tools. The assessment identified key security issues, including an exposed database service, missing HTTP security headers, and server information disclosure. These findings highlight the importance of secure server configuration and regular vulnerability assessments to reduce security risks. Overall, this project provided practical experience in identifying web application vulnerabilities, analyzing security weaknesses, and understanding basic penetration testing techniques in a controlled environment.